



IDENTITY LAYER (OUT OF SCOPE)

Screenshot 2026-07-07 124745.jpg

Table 1: Identity Vault

ARCHITECTURE OVERVIEW:

This table acts as your 'Identity Sanctuary'. It maps physical, real-world customer identifiers (Names, SSNs, personal data) strictly to a random surrogate Key (UID). This completely decouples personal identification from financial account identifiers.

PCI DSS v4.0.1 Scoping:

Under PCI DSS v4.0.1, because this table does not store, process, or transmit Primary Account Numbers (PANs), it is completely OUT OF SCOPE for compliance audits. This reduces assessment footprints drastically.

Privacy Controls (GDPR):

Under GDPR/ISO 27701, this table represents maximum exposure since it holds direct Personally Identifiable Information (PII). It falls strictly under standard data minimization and processing consent rules, while keeping credit cards out of its footprint.

LOGICAL MAPPING LAYER (OUT OF SCOPE)

Screenshot 2026-07-07 124800.jpg

Table 2: Account Mapping

ARCHITECTURE OVERVIEW:

This table serves as a safe translation layer establishing a 1-to-many relationship mapping a specific customer profile (UID) to their corresponding card vaults (CCid) without revealing the credit card string itself.

PCI DSS v4.0.1 Scoping:

Because this database does not process or preserve true credit card strings (PANs), it remains entirely OUT OF SCOPE for PCI DSS auditing rules, saving substantial infrastructural overhead.

Privacy Controls (GDPR):

Acts as a surrogate bridge. If Table 1 is deleted due to GDPR's 'Right to be Forgotten' (Article 17), this link is dissolved instantly without destroying the historical transactional values in the payment ledger.

PCI CARDHOLDER DATA ENVIRONMENT (CDE) - MAXIMUM

Screenshot 2026-07-07 124818.jpg

IN-SCOPE

Table 3: The Prescriptive CDE (The Vault)

ARCHITECTURE OVERVIEW:

This is your primary Cardholder Data Environment (CDE). It maps the surrogate Key (CCid) strictly to the heavily encrypted Primary Account Number (PAN). Absolutely NO SENSITIVE AUTHENTICATION DATA (SAD), such as CVVs or PIN blocks, is stored here post-authorization.

PCI DSS v4.0.1 Scoping:

This is the CORE TARGET of a PCI DSS Audit. Every single control in Requirements 1-12 applies here. It must run on fully isolated infrastructure (network segmentation), implement AES-256 database-level encryption, and force strict multi-factor authentication controls.

Privacy Controls (GDPR):

Since the PAN is completely tokenized and decoupled from user names inside this database (requiring Table 2 and Table 1 to re-identify the human), this implementation satisfies GDPR's requirements for Pseudonymization (Article 32).

STATELESS CRYPTOGRAPHIC ENGINE

Screenshot 2026-07-07 124834.jpg

The Tokenization Handshake Module

ARCHITECTURE OVERVIEW:

When an active purchase is made, the application validates the user identity through Table 1 and pulls the mapped credit index. Instead of retrieving or keeping static verification codes, this module generates a short-lived ephemeral Dynamic CVV (dCVV).

PCI DSS v4.0.1 Scoping:

Perfectly aligns with PCI Requirement 3's strict prohibition against storing Sensitive Authentication Data (SAD) post-authorization. Because the dynamic token operates like a rolling RSA code, it instantly expires and is permanently zeroized, leaving zero footprint for auditors to scrub.

Privacy Controls (GDPR):

Maintains optimal data minimization principles. It only generates transient variables that exist in ephemeral cache state for 90 seconds, satisfying the 'Security of Processing' guidelines.